

GLBA Compliance Checklist

Resource Category: Compliance & Security · **Updated:** July 2026

This checklist maps out the necessary regulatory actions required to adhere to the Gramm-Leach-Bliley Act (GLBA), specifically focusing on the Financial Privacy Rule and the Safeguards Rule.

1. Administrative Safeguards

Ensure the organizational protocols and personnel structures are in place.

Program Management

Appoint a qualified individual/Security Officer to coordinate the Information Security Program.

Perform a comprehensive, documented risk assessment identifying internal and external threats to NPI (Nonpublic Personal Information).

Design and implement a regular employee cybersecurity and awareness training program.

Vendor Management

Draft policies requiring all third-party service providers to sign GLBA-compliant data security agreements.

Periodically monitor and assess the security practices of external vendors with access to systems.

2. Technical & Physical Safeguards

Deploy strong digital and physical defenses to protect consumer records.

Access Controls & Encryption

Implement Multi-Factor Authentication (MFA) for all employees and users accessing customer data.

Apply data encryption measures both for data at rest and data in transit.

Enforce the principle of least privilege, restricting user accounts to data essential for their specific roles.

Maintain secure data disposal protocols (e.g., destroying or purging records after 2 years of inactivity).

Monitoring & Incident Response

Set up automated security logs and systems to actively monitor unauthorized or suspicious access attempts.

Develop and regularly test a written Disaster Recovery (DR) and Business Continuity Plan (BCP).